

Acceptable Use Policy

Guidelines for employee data handling and system usage — with employee acknowledgment form

Document ID	POL-AUP-001
Version	1.0 (template)
Classification	Internal
Owner	[Data Protection Officer / IT Security Manager]
Approved by	[Name, Title]
Effective date	[DD Month YYYY]
Next review	[DD Month YYYY — review at least annually]

Customization required

This template is a starting point published by the OpenDLP-LK community. Replace all bracketed placeholders, adapt the content to your organization's size, industry and risk profile, and obtain legal review before adoption. Aligned with Sri Lanka's Personal Data Protection Act (PDPA) No. 9 of 2022.

<https://opendlp-lk.github.io> • Licensed under MIT — free to use, adapt and redistribute.

1. Purpose

This policy defines acceptable and prohibited use of [Organization Name] information systems, devices and data. It protects the organization, its clients and its employees from data loss, legal liability and security incidents, and supports compliance with Sri Lanka's PDPA No. 9 of 2022.

2. Scope

Applies to all employees, contractors, interns and third parties using organizational systems, accounts or data, on any device (corporate or personal), from any location.

3. Acceptable Use

- Access only the data and systems required for your job responsibilities.
- Use approved communication channels ([corporate email / approved collaboration tools]) for business data; use the approved secure transfer service for sensitive files.
- Follow the Data Classification Framework when creating, labeling, storing and sharing documents.
- Use strong, unique passwords and enable multi-factor authentication on all corporate accounts.
- Lock your screen whenever you leave a device unattended (Win+L / Ctrl+Cmd+Q).
- Encrypt sensitive data before transmission; verify recipient addresses before sending.
- Report suspected security incidents, phishing and data exposure immediately to [security contact] — reporting an honest mistake quickly will always be treated more favorably than concealment.
- Complete mandatory security and data protection training on schedule.

4. Prohibited Activities

- Sharing Confidential or Restricted data via personal email accounts or personal messaging apps (WhatsApp, Viber, Telegram personal profiles).
- Storing organizational data on unapproved cloud services or personal storage accounts.
- Using unauthorized USB drives or external storage devices.
- Photographing or taking screenshots of sensitive data without documented authorization.
- Forwarding confidential emails or auto-forwarding corporate mail to external addresses.
- Printing sensitive documents without using secure-release printing, or leaving printouts unattended.
- Sharing login credentials, access tokens or MFA codes with anyone, including colleagues and IT staff.
- Attempting to disable, bypass or circumvent DLP agents, endpoint protection or other security controls.
- Installing unapproved software or browser extensions on corporate devices.
- Using corporate systems for illegal activity, harassment, or unauthorized commercial ventures.

5. Remote Work Requirements

- Connect through the company VPN when accessing internal resources.

- Secure your home network: strong Wi-Fi password (WPA2/WPA3), updated router firmware, no default admin credentials.
- Maintain physical security of devices and documents; do not allow family members to use corporate devices.
- Use a privacy screen and avoid viewing sensitive data in public places.
- Dispose of printed sensitive material by shredding — never in household waste.
- Do not use public/untrusted Wi-Fi for sensitive work without the VPN.

6. BYOD Requirements

- Register personal devices with [IT Department] before accessing company data.
- Install and keep active the required MDM/MAM profile; removal terminates access.
- Keep the device OS and applications updated with security patches.
- Enable device encryption, screen lock (max 5-minute timeout) and biometric/PIN protection.
- Keep business data inside the managed work profile/container; do not copy it to personal apps.
- Report lost or stolen devices within [4] hours; the organization may remotely wipe the work profile.

7. Monitoring Notice

The organization monitors use of its systems — including email content inspection, web filtering, DLP endpoint agents and access logs — to the extent permitted by law, for security and compliance purposes. Monitoring is proportionate, documented, and personal data collected through monitoring is itself handled under the PDPA. Users should have no expectation of privacy when using corporate systems for personal purposes.

8. Enforcement

Violations may result in warning, mandatory retraining, suspension of access, disciplinary action up to termination, and legal action where required by law. Suspected criminal conduct will be reported to law enforcement.

Employee Acknowledgment Form

I acknowledge that I have read, understood and agree to comply with the [Organization Name] Acceptable Use Policy (version [1.0], dated [date]). I understand that violations may result in disciplinary action up to and including termination, and that the organization monitors use of its systems as described in Section 7.

Employee full name:

NIC / Employee ID:

Department:

Position:

Signature:

Date:

Witnessed / processed by (HR):

HR representative name:

Signature:

Date:

Retention

HR must retain signed acknowledgments for the duration of employment plus [2] years. Re-acknowledgment is required after every material policy revision and at least every [2] years.